

Figure 1: Basic cryptography functionality

of its own installed SSL certificate (for the hosted website URL). At this point, the browser checks the validity and authenticity of the certificate, by using the set of public keys on it. On finding it to be acceptable, the browser sends back a digitally signed response to the server to initiate further secure communication. If the server certificate cannot be verified for authenticity, the browser alerts the user about this situation. It's important to note that while SSL helps achieve security, there is an overhead, since TCP/IP by default does not provide any security—adding the encryption layer onto the existing protocol frame can result in bigger TCP packets.

Cryptographic attacks

Network administrators commonly invest time and money to design security around applications, servers and other infrastructure components, but tend to take cryptographic security less seriously. Before going into the various attacks, let's understand first that cryptography is all about keys, the data, and the encryption/decryption of the data, using the keys. A few cryptographic attacks try to decipher the key, while others try to steal data on the wire by performing some advanced decryption. Let's take a look at a few common attacks on cryptography.

The SSL MITM attack: In this case, the attackers intrude into the network and establish a successful man-in-the-middle connection. The attackers silently watch the HTTPS traffic on the wire, and wait for the targeted website to respond to some browser's HTTPS request. As we learnt earlier, the server is supposed to send its digital certificate to the browser as a part of the SSL handshake process. The attackers grab this certificate, and note down various details such as the domain name, expiration date, cipher strength, etc. The attackers then create their own certificate (also called a self-signed certificate), containing the same information as that of the captured certificate. From this point on, the man-in-the-middle attackers intercept each browser request and respond with the fake certificate. As a normal response to such a situation, the Web browser pops up a warning to the user, which in most cases is ignored, and thus the attackers are successful. Further, on the server side, the attackers establish a separate HTTPS connection to complete the request, and the result of the response is fed back into the browser on the connection already established. This gives the attackers complete control on the

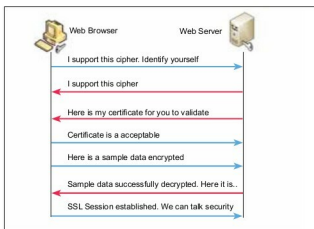


Figure 2: A secure browsing mechanism

SSL traffic, and helps them steal the personal information. Since this attack involves a real intrusion into the network, it is less likely to happen, but can result in serious data loss. Also, since the attackers are not breaking the request-and-response chain, it becomes tough to detect the data theft.

The SSL MITB attack: Similar to the attack mentioned above, in this case, the attackers inject a JavaScript code snippet into the browser to create a man-in-the-browser situation. This snippet monitors all SSL activities and records the session. While this is happening, the attackers also record the encrypted version of the same session, and programmatically try to find out the cipher strength and the key, besides stealing data. This attack is becoming more popular of late, due to multiple open source browsers, and the various security vulnerability problems with each of them.

Key hijacking: This is another intrusive type of attack, whereby the attackers gain access to the Web server hosting the website (by using one of the many intrusion techniques already discussed in previous articles of this series). Once the server is compromised, the attackers use an elevated privilege attack to gain access to the certificate store, from where the private key can be obtained. The attackers then use packet sniffing to download an entire HTTPS session, and store it for offline decryption. The decryption process needs the private key, which is already stolen; and the public key, which is available in the browser's trusted authority key store. The data set so deciphered might reveal vital personal information such as user IDs, addresses, credit-card numbers, etc, assuming that the targeted website sells goods online using e-commerce technology.

The birthday SSL attack: This attack relies on a mathematical theory called the birthday problem, which says that statistically, in a set of randomly selected people, some pairs of people will have the same birthday. The probability increases as the number of people grows. In cryptography, the data integrity is established using a hash or checksum, which is calculated at both ends of the transmission, to ensure that the data is not tampered with. Birthday attacks target the hash,